Caso práctico – Gobierno y Aseguramiento de TI (COBIT)

Propuesta de evaluación

Contexto del problema:

La organización administra aproximadamente 1.000 aplicaciones y ha recibido observaciones relacionadas con riesgos operativos, cumplimiento normativo y generación de valor para el negocio. Esta situación evidencia la necesidad de fortalecer el gobierno de TI mediante un marco estructurado.

El marco COBIT (Control Objectives for Information and Related Technologies) provee los lineamientos necesarios para evaluar, dirigir y monitorear la gestión de TI de forma alineada con los objetivos del negocio. Esta propuesta plantea evaluar el nivel de adherencia y aseguramiento en dos procesos críticos seleccionados que se van a mencionar a continuación.

Procesos de COBIT seleccionados:

Se seleccionaron dos procesos que se consideran relevantes dado el contexto de la organización, estos son:

Proceso	Nombre	Relevancia
APO12	Gestión del Riesgo	Con 1.000 aplicaciones, es crítico identificar, analizar y responder a riesgos de TI de forma sistemática.
DSS05	Gestión de Servicios de Seguridad	Protege la infraestructura y las aplicaciones frente a amenazas y vulnerabilidades activas.

De los 40 procesos definidos por COBIT, se seleccionaron **APO12 (Managed Risk)** y **DSS05 (Managed Security Services)** por su relación directa con las necesidades de la organización en términos de gestión de riesgos y aseguramiento de TI.

La selección se realizó pensando en un orden secuencial, primero identificar, analizar y priorizar los riesgos tecnológicos y cibernéticos mediante APO12, y posteriormente evaluar si los controles y servicios de seguridad implementados a través de DSS05 son suficientes para mitigarlos adecuadamente.

Otros procesos como cumplimiento normativo (MEA03) o gestión de continuidad (DSS04) son igualmente importantes, pero se propone abordarlos una vez que la organización tenga una base sólida de gestión de riesgo y seguridad, aspectos que son fundamentales.

Criterios de aseguramiento:

APO12 - Gestión del Riesgo

Se evalúa la capacidad de la organización para identificar, analizar, responder y monitorear los riesgos de TI de manera continua y sistemática

- Identifica y documenta los riesgos tecnológicos relevantes.
- Prioriza los riesgos según impacto y probabilidad.
- Mantiene un perfil de riesgos actualizado.
- Define responsables para la gestión de riesgos.
- Realiza seguimiento periódico a los riesgos identificados.
- Comunica los riesgos a las áreas responsables y a la dirección.
- Cuenta con planes de respuesta y tratamiento de riesgos.

DSS05 - Managed Security Services

Se evalúa la capacidad de la organización para implementar y usar controles de seguridad que permitan proteger la información, prevenir incidentes y responder adecuadamente ante amenazas y vulnerabilidades de TI.

- Cuenta con controles de seguridad definidos y aplicados.
- Gestiona adecuadamente accesos y privilegios de usuarios.
- Protege los sistemas frente a amenazas y vulnerabilidades.
- Realiza monitoreo de eventos e incidentes de seguridad.
- Ejecuta revisiones periódicas de vulnerabilidades y controles.
- Tiene mecanismos de respuesta ante incidentes.
- Capacita a los usuarios en buenas prácticas de seguridad.

Enfoque de evaluación

Evaluación a nivel organizacional:

La evaluación buscará determinar qué tan alineados están los procesos de gestión de riesgos y seguridad con los objetivos del negocio y el marco COBIT. Para ello se revisará:

- Existencia de políticas: ¿hay políticas, procedimientos y lineamientos formales documentados y vigentes?

- Roles y responsabilidades: ¿están definidos los responsables de la gestión de riesgos y seguridad en la organización?
- Gestión centralizada: ¿existe un proceso que consolide los riesgos y controles de forma integral?
- Indicadores de seguimiento: ¿se miden y reportan métricas de riesgo y seguridad de forma periódica?
- Monitoreo y mejora continua: ¿hay evidencia de que los procesos se revisan y mejoran con el tiempo?
- Participación de áreas: ¿las áreas de negocio y tecnología trabajan coordinadas en la gestión del riesgo?

El objetivo es identificar el nivel de madurez general de la organización frente a la gestión del riesgo tecnológico y la seguridad.

Evaluación a nivel de aplicación:

Como aplicación piloto se selecciona SAP, sistema de planificación de recursos empresariales utilizado para la gestión financiera, contable y operativa de la organización. Se trata de un sistema crítico, porque una falla o compromiso de seguridad en SAP tiene impacto directo sobre la operación del negocio, la integridad de la información financiera y el cumplimiento.

Para APO12 - Gestión del Riesgo:

- ¿Están identificados y documentados los riesgos específicos de SAP, incluyendo riesgos de disponibilidad, integridad de datos y acceso no autorizado?
- ¿Se ha evaluado el impacto que tendría sobre el negocio una interrupción o compromiso de este sistema?
- ¿Existe un plan de tratamiento activo para los riesgos identificados, con responsables y fechas definidas?
- ¿Se hace seguimiento periódico a las vulnerabilidades conocidas que afectan las versiones de SAP en producción?

Para DSS05 - Gestión de Servicios de Seguridad:

- ¿Los accesos a SAP están controlados por roles bien definidos, con principio de mínimo privilegio y revisión periódica?
- ¿Se monitorean los eventos de seguridad dentro del sistema y hay alertas ante comportamientos anómalos?
- ¿Las actualizaciones y parches de seguridad de SAP se aplican dentro de los plazos establecidos, especialmente aquellos relacionados con vulnerabilidades críticas?
- ¿Existen respaldos periódicos, mecanismos de recuperación probados y trazabilidad de las operaciones realizadas en el sistema?
- ¿Se ha realizado alguna prueba de seguridad sobre SAP en el último año

Propuesta de implementación:

La iniciativa es importante presentarla como un enfoque progresivo que permita identificar el estado actual de la organización, priorizar riesgos y definir acciones de mejora alineadas con COBIT y los objetivos del negocio.

Fase	Descripción	Entregable
Diagnostico	Reuniones con líderes de TI y negocio para entender el estado actual. Revisión de lo que ya existe (políticas, controles, incidentes previos)	Línea base del estado actual.
Evaluación y análisis	Comparar el estado actual frente a las buenas prácticas de COBIT para identificar debilidades, brechas y oportunidades de mejora. Se priorizarán los riesgos con mayor impacto para el negocio, los procesos más críticos y los controles ausentes.	Informe de brechas con riesgos priorizados de acuerdo con su impacto.
Plan mejora	• Fortalecimiento de controles. • Definición de métricas e indicadores de seguimiento. • Formalización de procesos. • Mejoras en monitoreo y gestión de vulnerabilidades. • Evaluación profunda en 5 a 10 aplicaciones críticas. Capacitación y concientización.	Hoja de ruta aprobada con responsables y fechas.
Seguimiento y evolución	Establecer revisiones periódicas para medir avances, garantizando mejora continua y alineación con las necesidades del negocio.	Reporte de hallazgos en el tiempo.
Escalamiento	Se replica el modelo validado en el piloto hacia el resto de las 1.000 aplicaciones de forma progresiva y medible.	Cobertura total.

La gestión del riesgo tecnológico no es un tema exclusivo del área de TI, es una responsabilidad compartida entre la tecnología y el negocio. Una organización con 1.000 aplicaciones que no tiene visibilidad clara sobre sus riesgos no está en condiciones de proteger lo que más importa.